

State of The Underground 2026

Executive Summary

The global threat landscape is changing, but that does not mean risk is receding. AI is beginning to accelerate key parts of the attack lifecycle, from phishing and vulnerability research to malware development and operational planning. At the same time, geopolitical tensions continue to shape hacktivist and state-linked activity, pushing threat actors toward higher-impact targets.

The central story is that while threats are changing shape, defenders must remain as vigilant as ever. Ransomware and hacktivism increased, AI became more visible in attacker workflows, and geopolitical tensions influenced who and what attackers targeted. Where Bitsight observed some indicators declining – including breaches, endpoint logs, compromised credentials, and card listings – those declines may reflect disruption efforts, changing visibility, reuse of previously exposed data, or shifts in how attackers monetize access. Taken together, a quieter signal does not mean a smaller threat. As frontier AI models like Mythos compress the time between exposure and exploitation, defenders need better context to prioritize the risks most likely to lead to real-world impact.

- AI is emerging as an accelerant.
- Bitsight Threat Intelligence observed significant underground discussion of AI tools, including roughly 5 million mentions of Gemini, 1.4 million mentions of ChatGPT, 656,000 mentions of Claude, and 697,000 mentions of Grok.
- Ransomware continued to grow. Ransomware groups posted 6,883 unique attacks in 2025, up 19% from 2024. Active leak sites rose from 86 to 115, a 34% increase.

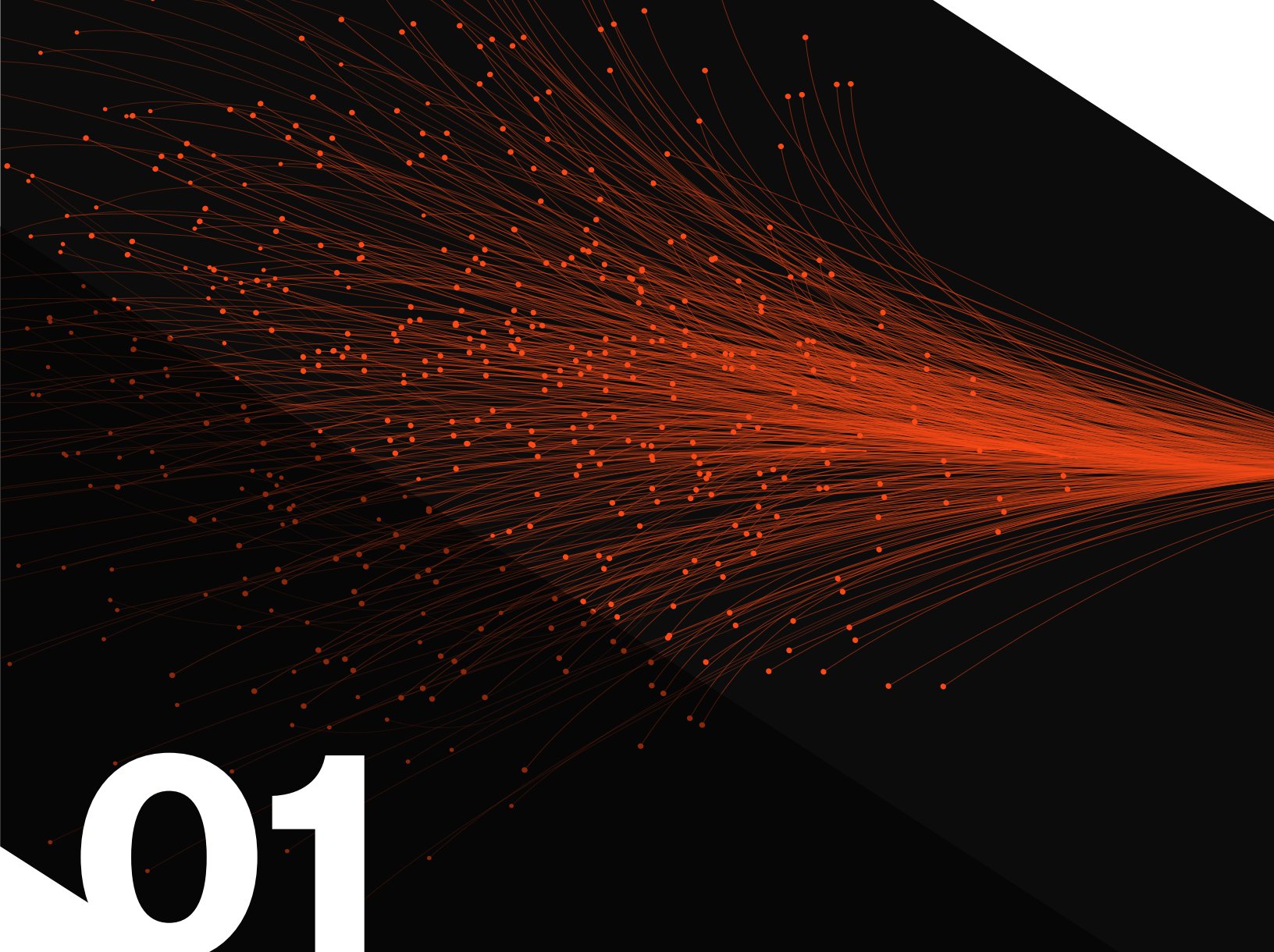
- Breach activity declined, but risk did not disappear. Breach incidents fell from 5,865 in 2024 to 3,447 in 2025. Indonesia became the most represented country in 2025 with 484 incidents, followed by the United States at 407.
- Compromised credentials remain a primary entry point. Bitsight observed 2.8 billion unique compromised credentials in 2025. Credential volumes grew at a 92% compound annual rate from 2022 to 2025.
- The malware economy is increasingly modular. Listings were dominated by RATs, stealers, bots, and crypters, with repeated listings for checkers, OTP bots, and credential validation tools.
- Hacktivism remained tied to geopolitics. Activity clustered around geopolitical events, driven by ideological motivations rather than financial gain.
- State-linked actors prioritized persistence. Common themes included long-term access, intelligence collection, credential abuse, and exploitation of public-facing systems.
- The defender window is tightening. Faster exploit development, widespread tooling, and AI-assisted workflows may reduce the time between discovery and exploitation.



The threat landscape in 2025 became more distributed, more adaptive, and in several areas more mature.”

Emma Stevens

Threat Intelligence Researcher, Bitsight



01

Introduction

The cyber threat landscape is in constant flux. Attackers are mercurial, but understanding where they might strike on any given day is a necessity for defenders.

Bitsight's 2026 State of the Underground report provides a data-driven view of this constantly evolving landscape, drawing on Bitsight Threat Intelligence (TI) and research across underground forums, breach marketplaces, malware telemetry, vulnerability tracking, the deep and dark web, and open-source reporting.

Our findings demonstrate how threat actors are refining their tactics, techniques, and procedures (TTPs) in response to new technologies, shifting defenses, and geopolitical tensions. Each section of this report focuses on a different aspect of that evolution: how AI is entering attacker workflows, how ransomware is maturing as a criminal market, how breach and credential activity shifted, and how geopolitical dynamics are shaping who gets targeted and how.

AI is disrupting technological development across many industries, and this is true for the underground economy as well. Attackers are using a variety of tools to develop malware and the malware ecosystem in general, without the guardrails that most defenders have. No doubt this is driving a maturity in the ransomware market with attackers able to not just write ransomware, but to set up marketplaces. As geopolitical tensions rise, ideologically motivated hacktivism increases in prominence as nation state actors prioritize long-term access, intelligence collection, and strategic disruption. This rise in hacktivism may be contributing to attackers shifting away from “traditional” targets like credential stealing.

These shifts in cyber risk are less about a single metric moving up or down and more about how attackers are adapting.

Where signals appear to be quieting, the underlying risk is simply changing shape.

Summarizing a year of cyber threat intelligence data that is in constant flux can often feel like a quixotic endeavor. It’s easy to get lost chasing individual campaigns and threat actors, marveling at their new innovations. But it’s crucial to stop, take a step back, and see the forest through the trees on a periodic basis. That is why Bitsight produces the State of the Underground report. Because seeing the bigger picture allows us to see how it’s evolving and how we can help defenders now and in the future.

This analysis is based on aggregated Bitsight TI throughout the 2025 calendar year and focuses on how the underground ecosystem is evolving, including closed underground communities, threat actor channels, dark web marketplaces, vulnerability intelligence, malware and endpoint telemetry, and public incident reporting. Where appropriate, findings include multi-year trend comparisons to provide context for what changed (and what did not).





02

Artificial Intelligence

As AI is becoming part of just about everyone's workflow, AI is also becoming part of threat actor workflows. In 2025, Bitsight TI observed significant discussion of mainstream AI tools across closed forums, threat actor Telegram channels, dark web marketplaces, and underground forums. This included roughly 5.1 million mentions of Gemini, 1.4 million mentions of ChatGPT, 656,000 mentions of Claude, and 697,000 mentions of Grok.

Number of mentions by platform

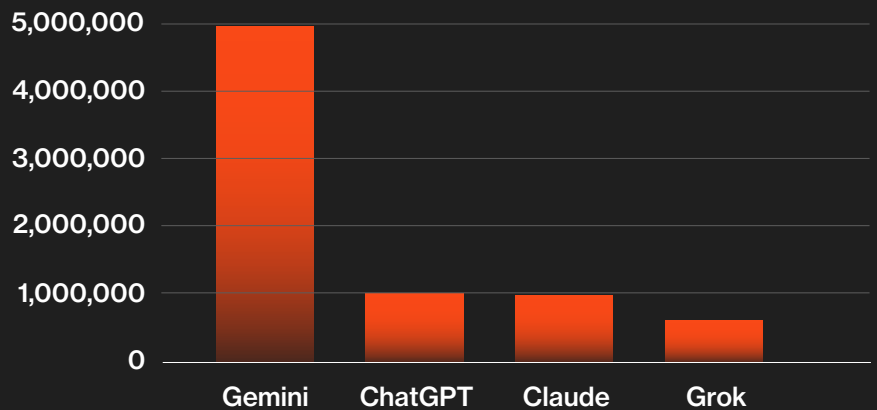


Figure 1. Number of AI mentions on the underground.

Grok was most associated with malware such as Wirex, Apocalypse, and BlackRock. ChatGPT discussions aligned most frequently with Katana, Lumma, and Lumma Stealer. Gemini was commonly discussed along with Robinhood, Gorilla, and Cleanup malware. Claude activity was especially concentrated around Cleanup, Jest, and Global.

AI mention by malware type

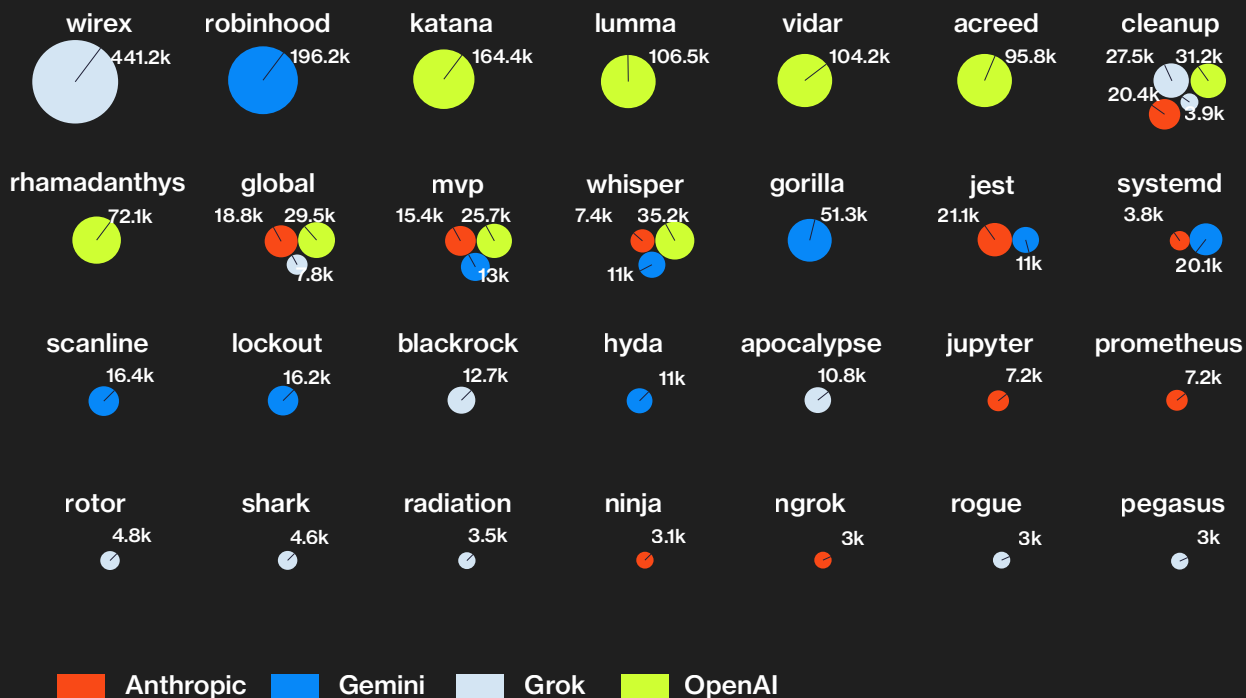


Figure 2. Relationships of AI tool mentions by malware type.

While we can't confirm how these tools are being used in every case, they do show that mainstream AI tools are becoming embedded in underground conversations tied to malware development, targeting, and attack planning. Indeed, nearly all of these providers have guardrails that should prevent the development of malicious software (though Bitsight TI also observed threat actors actively discussing how to jailbreak those platforms, likely with the goal of circumventing exactly those restrictions).

More likely, threat actors are studying AI just as defenders are, only for slightly different purposes: to understand their capabilities. AI risk has moved beyond just novelty to encompass speed, scale, and easier execution, especially in the parts of attacker workflows that are not explicitly malicious.

Beyond underground discussion, AI is also significantly expanding the attack surface. In 2025, Bitsight observed a 360% increase in exposed AI-related tooling, which equates to more than one million exposed services.

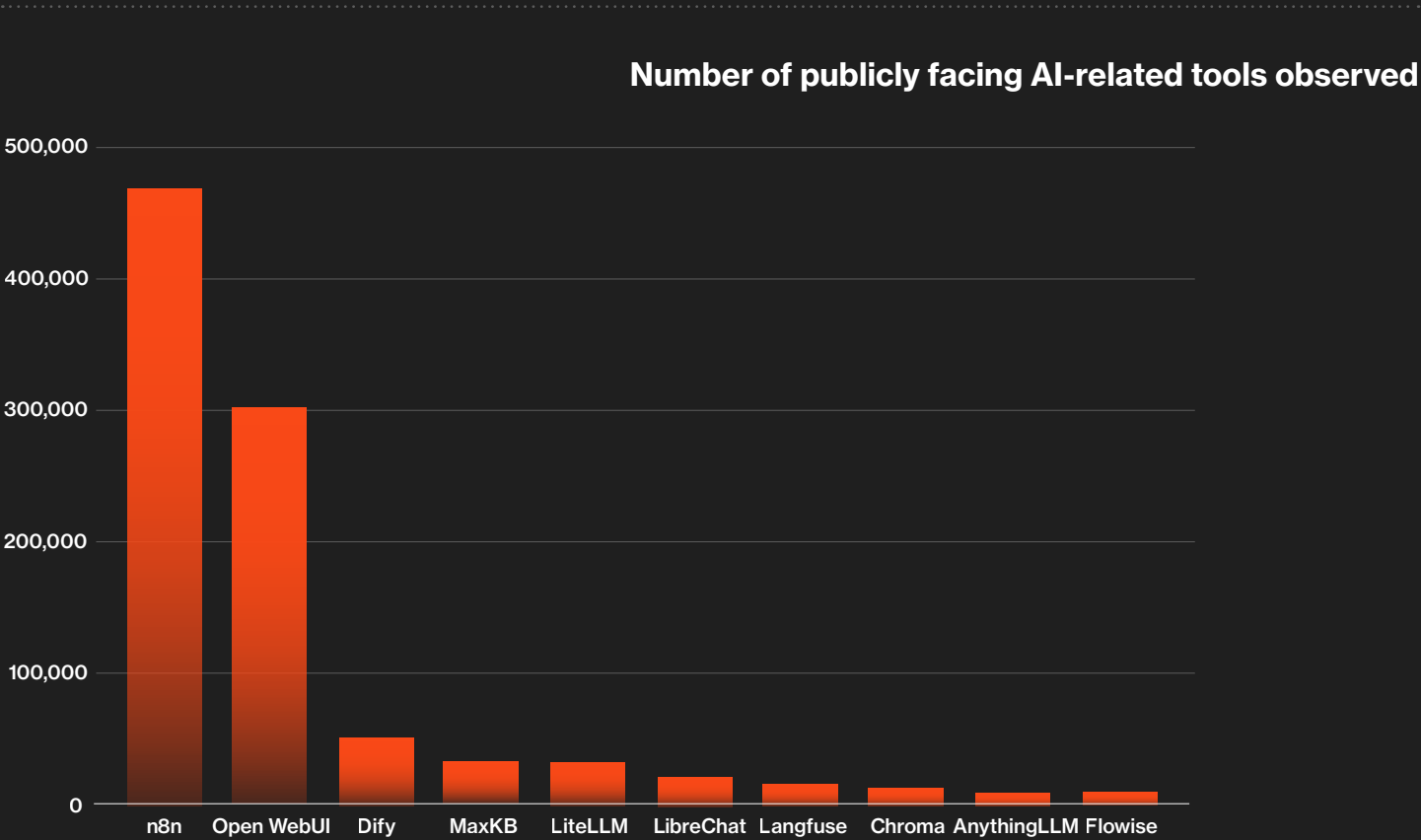


Figure 3: Publicly exposed AI tools by endpoint count in 2025.

A 2026 campaign referred to as Hexagonal Rodent illustrates what this looks like in practice. The group, closely linked to Famous Chollima, targeted Web3 developers using malware including BeaverTail, OtterCookie, and InvisibleFerret alongside AI-enabled tools such as Cursor and ChatGPT, creating a visible example of how threat actors are integrating AI into active operations.

It's important to reiterate that the same AI tools used by defenders, researchers, and developers are also accessible to threat actors. As the window between vulnerability, discovery, and exploitation shrinks, prioritization will play a larger role as both defenders and threat actors learn how to leverage AI for their needs. We are no longer in an era where critical vulnerabilities can be patched on a schedule.

Key takeaways

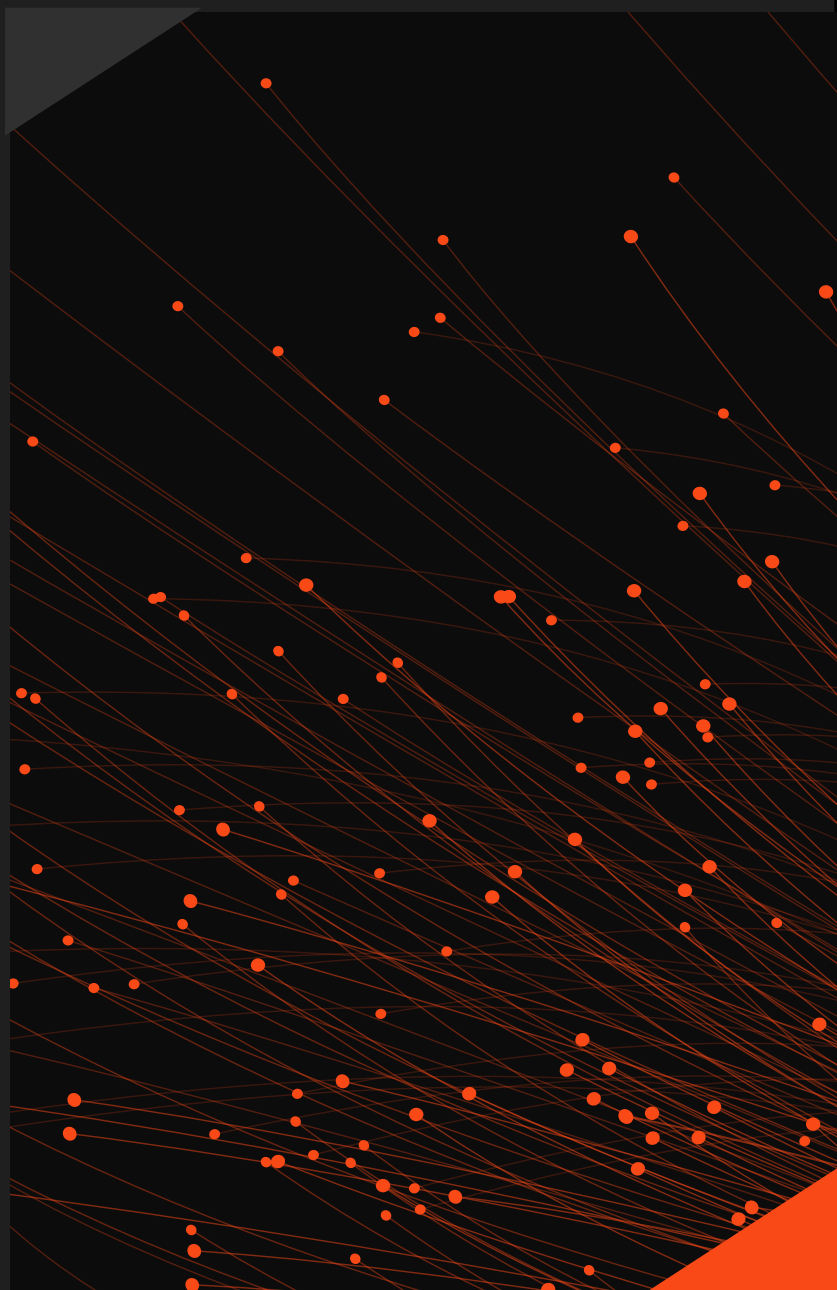
+360%

Exposed AI-related services surged 360% in 2025, exceeding one million exposed instances.

5.1M Gemini 1.4M ChatGPT

Underground forums logged 5.1M Gemini mentions and 1.4M ChatGPT mentions, tied to active malware families.

The primary risk is the speed, scale, and reduced execution difficulty for attackers.





Ransomware

Ransomware continues to be one of the easiest ways for attackers to monetize their malicious activities. In 2025, ransomware groups posted 6,883 unique attacks, up 19% from 5,774 in 2024. Active data leak sites (DLS) rose 34% from 86 to 115. Ten ransomware groups were responsible for 57.7% of all attacks in 2025, up from 53.2% in 2024.

Ransomware attacks

Overall, ransomware groups posted about 5,021 unique attacks in 2024, an increase from 4,029 in 2023.

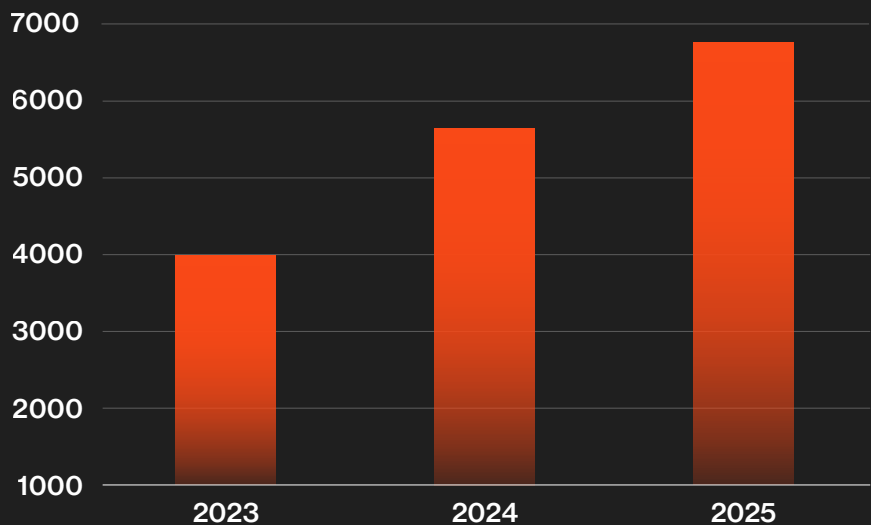


Figure 4. Number of ransomware attacks over the past three years.

The top 5 groups – Qilin, Akira, ClOp, Play, and INC Ransom – were responsible for 41.4% of that 57.7%. All of the top 5 threat groups were either Russia-linked or Russian speaking.

Location and language matter because ransomware is not always opportunistic or financial. Geopolitical tensions can heavily influence targeting. The dominance of Russia-linked and Russian-speaking groups is not incidental—it shapes who gets targeted and why. Groups like NoName057(16) increased their targeting specifically on US and UK critical infrastructure and key resources, seemingly driven by tensions stemming from the conflict in Russia and Ukraine.

The median ransomware payment hit \$60,000 (a 368% increase), while total ransom payments declined 66%, suggesting victims were less willing to pay. This could reflect increased legislation banning some ransom payments, improved data backups, and organizations refusing to continue the cycle. However, fewer ransom payments does not mean lower ransomware risk. With direct payments declining, threat actors appear to be shifting their calculus: the cost of downtime, reputational fallout, and legal and continuity pressure may now be doing more coercive work than the ransom demand itself.

Top ransomware victims per country (2025)

Victim geography and sector targeting remained consistent year over year. The US accounted for 59.4% of ransomware victims within the locations definitively identified, followed by Canada.

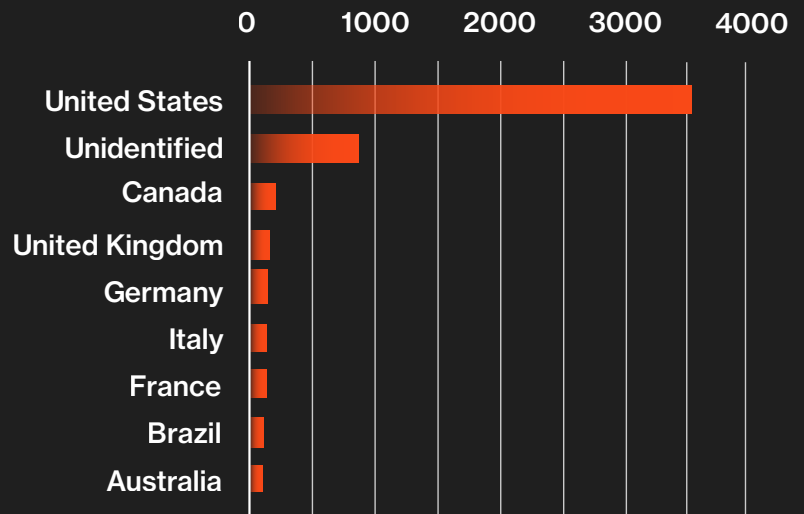


Figure 5: Number of ransomware victims identified per country.

Manufacturing remained the most targeted sector for ransomware attacks, followed by business services and engineering. These industries are attractive to threat actors because downtime creates immediate financial losses and operational pressure. The 2021 Colonial Pipeline breach continues to illustrate this: the attack impacted 50 million people and cost the company tens of millions of dollars, while the ransom payment itself was \$4.4 million. The disruption, not the payment, was the cost.

Ransomware risk is no longer tied to the rise or fall of a single group. The market appears durable, layered, and capable of absorbing disruption. Threat actors are resilient and have proven their ability to rebuild after law enforcement disruption. LockBit alone has now cycled through five major iterations, demonstrating that takedowns, while impactful, have not permanently degraded the group's operational capacity. Ransom payments may be down, but the threat is not.

Key takeaways

+19%

Ransomware attacks rose 19% in 2025, even as total ransom payments fell 66%.

58%

Ten groups accounted for nearly 58% of all attacks; the top five were all Russia-linked or Russian-speaking.

59.4%

The US represented 59.4% of identified ransomware victims; manufacturing was the most targeted sector.

+34%

Active data leak sites grew 34%, signaling market expansion.

04

Data breaches

Ransomware continues to be one of the easiest ways for attackers to monetize their malicious activities. In 2025, ransomware groups posted 6,883 unique attacks, up 19% from 5,774 in 2024. Active data leak sites (DLS) rose 34% from 86 to 115. Ten ransomware groups were responsible for 57.7% of all attacks in 2025, up from 53.2% in 2024.

Data breaches are the OG security incident, largely what defenders first started needing to lock down their networks. Observed breaches decreased 41% from 5,865 incidents in 2024 to 3,447 in 2025. However, this decline should not be interpreted as a reduction in risk. It likely reflects a mix of visibility changes, reporting gaps (including deliberate non-disclosure), changing attacker TTPs, and shifts in monetization.

Breach reporting may be down in part because it was never fully visible to begin with. APTs and nation-state actors typically do not advertise attacks on the dark web or other forums when their objectives are espionage, disruption, or strategic access. Reporting may be further limited by geopolitical factors, since some governments and organizations may be less likely to publicly disclose successful attacks perpetrated by perceived adversaries. And sometimes, ransomware breaches go unreported simply because organizations find it easier to pay quietly and move on.

Disruption activity could also contribute to the decline, though it's important to note that disruption is not the same as elimination. Bitsight, in coordination with the FBI and Microsoft, [helped disrupt Lumma Stealer infrastructure in 2025](#), reducing some visible credential- and stealer-driven activity. The respite was short-lived: in 2026, Lumma Stealer resurfaced and was leveraged in a large AI-related breach, showing that threat actors often reemerge after disruption.

At the same time, threat actors are adjusting as AI-enabled tools become more available, including looking for domino attacks in which multiple industries and companies can be hit from a single breach. This is driven in part due to declining ransomware payments, which are pushing threat actors toward higher-leverage targets. Already in 2026, Raptor Train, a Chinese Advanced Persistent Threat (APT), infected over 260,000 SOHO routers and IP cameras with malware, creating a botnet aimed at critical infrastructure. This provides a clear example of how nation-state actors are pursuing scale and systemic disruption over opportunistic financial gain.

Data breaches shared on underground forums

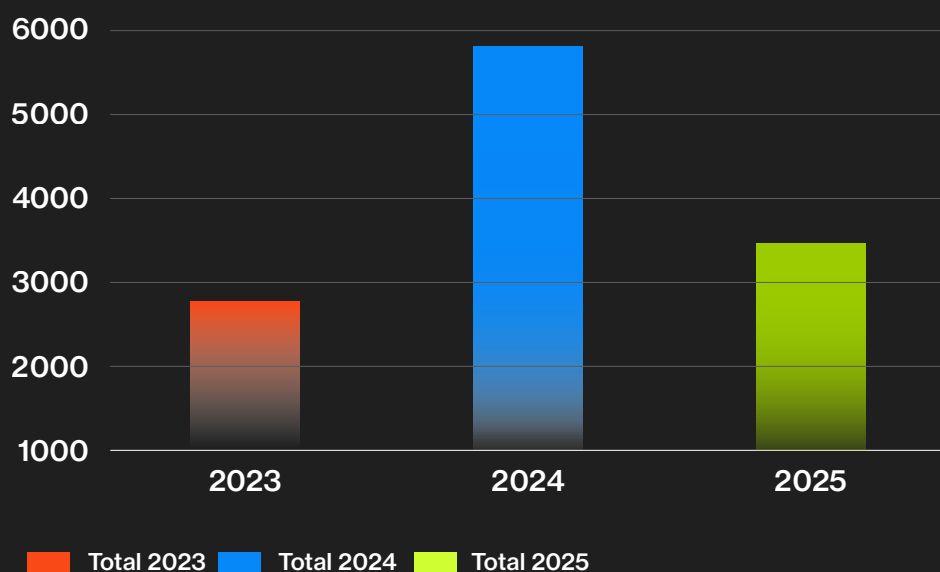


Figure 6. Number of data breaches shared on underground forums over the past three years.

Geographically, the United States led data breaches in 2024 but declined significantly in 2025. Indonesia became the most represented country in 2025, rising from 331 incidents in 2024 to 484 in 2025.

Change in data breaches from 2024 to 2025

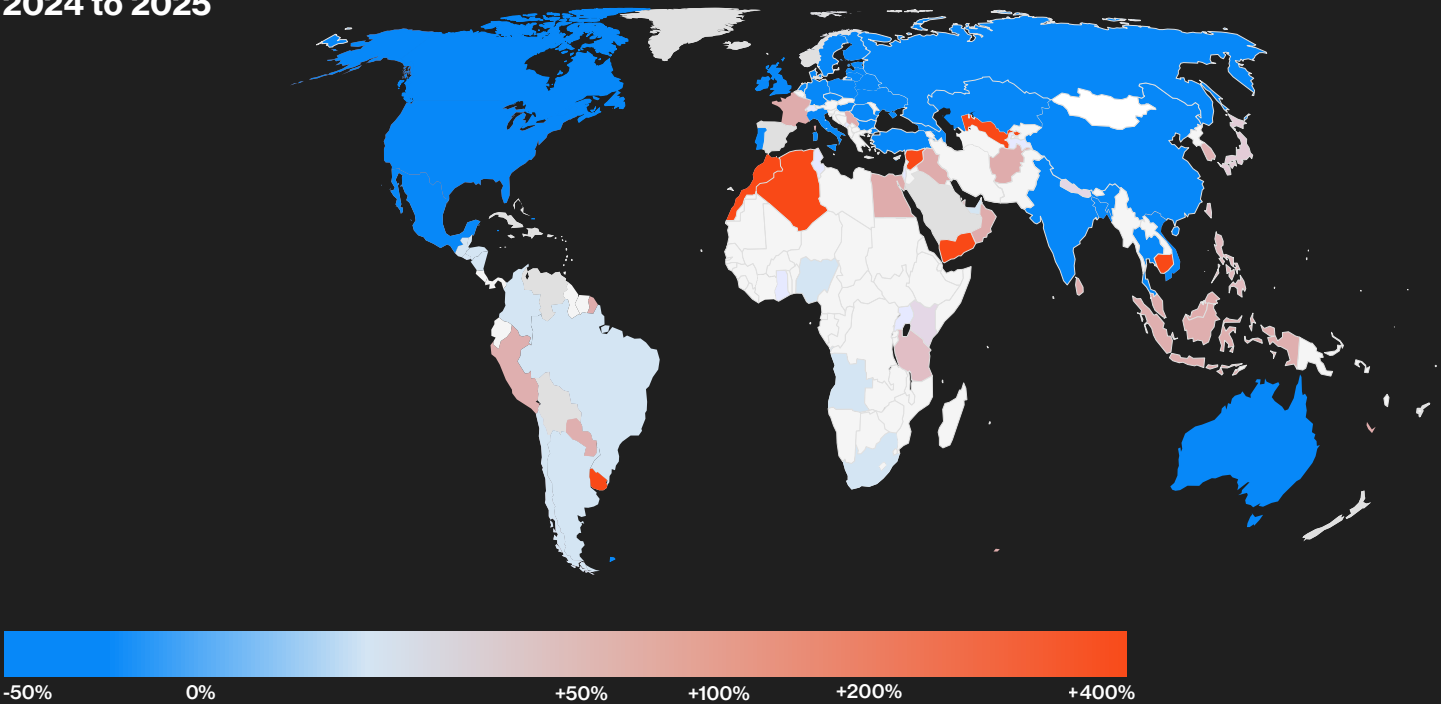


Figure 7. Relative change in observed data breaches from 2024 to 2025.

Relative change in proportion of data breaches

Sector distribution also shifted. In 2024, Technology led with 1,210 incidents. In 2025, Education led with 505 incidents, followed by Government/ Politics at 475 and Technology at 469. This suggests breach activity became less dominated by a single sector and more distributed across industries with personally identifiable information (PII) and operational and supply chain importance.

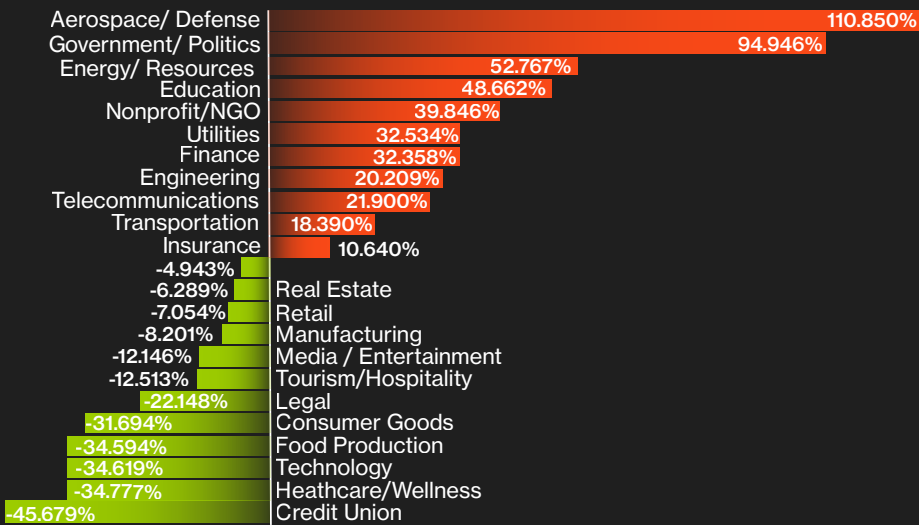


Figure 8. Relative change in data breach victim distribution by industry.

Breaches appear to be evolving based on geopolitical and financial goals rather than fading. Threat actors continue to target organizations that provide widespread access, disruption potential, or financial and legal leverage. Bitsight TI observed an increase in breaches associated with government/defense and utilities sectors worldwide, a trend attributable to geopolitical tensions that motivate targeting of critical infrastructure precisely because of the cascading impact on an adversary. Imagine a week without cell phone service, wifi, water, or electricity. The cost to business continuity would be severe.

For a perceived adversarial nation, it could be crippling. That is precisely the calculus threat actors are making and why a declining breach count should not be mistaken for a declining threat.

Key takeaways

-41%

Observed breaches fell 41% in 2025 compared to 2024, but the decline likely reflects reporting gaps and attacker behavior shifts, not lower risk.

Attacker focus shifted toward domino-effect targets, including critical infrastructure and defense, government, and utilities.

Indonesia surpassed the US as the most represented country in 2025.

505

Education led sector distribution in 2025 with 505 incidents, displacing Technology as the top target.

Malware

05

The malware market is highly active, commercialized, and purpose-built to lower the barrier to entry for attackers across the skill spectrum.

The most prevalent malware types were Remote Access Trojans (RATs), stealers, bots, and crypters. RAT listings appeared especially dominant, including Android RATs, Windows RATs, and multifunction RAT bundles with keylogging, file access, and remote code execution (RCE). Stealers targeting browsers, cryptocurrency wallets, and credentials also remained prolific.

Supporting tools appeared across the attack chain, including account checkers, brute-force tools, OTP bots, and admin panel scanners. These tools enable credential stuffing, account takeover, and validation of stolen data at scale, reinforcing credential abuse as a core operational focus.

Threat actors are increasingly relying on residential proxy services to avoid detection and appear as legitimate users, making it easier to impersonate executives and other high-value personnel. The scale of this activity is significant. Over 55 days, Bitsight observed more than 53M unique exit nodes, of which 15% were flagged for malware infections and 13% were flagged for riskware activity. This indicates that residential proxies both enable malicious activity and overlap heavily with compromise infrastructure.

The malware market is an interconnected ecosystem of tools sold, rented, reused, and combined across the attack lifecycle. This lowers the barrier to entry and allows less sophisticated actors to execute effective attacks. It also reinforces that identity and access remain central battlegrounds, since many of the tools in this dataset are designed not to break systems directly, but to exploit valid credentials and existing access. That dynamic is visible in the credential volumes discussed in a later section.

Key takeaways

RATs, stealers, bots, and crypters were the most prevalent malware types on underground forums in 2025.

Account checkers, OTP bots, and brute-force tools reinforced credential stuffing and account takeover at scale.

Residential proxy use grew significantly, with 28% of 53M observed exit nodes flagged for malware or riskware.

The malware market is a modular ecosystem that lowers barriers to entry for less sophisticated actors.

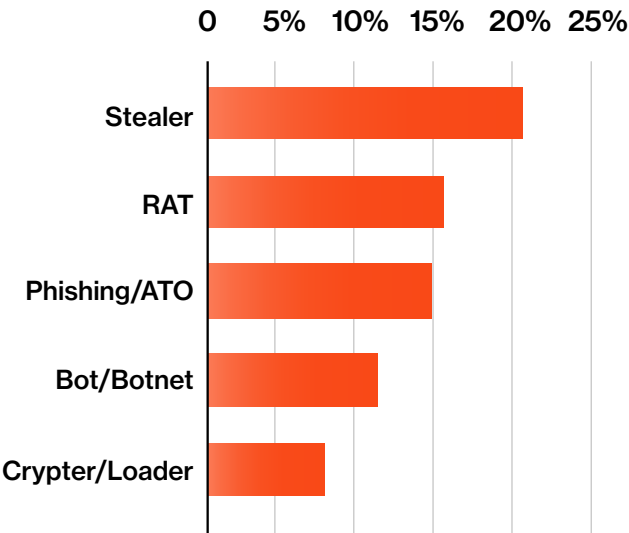
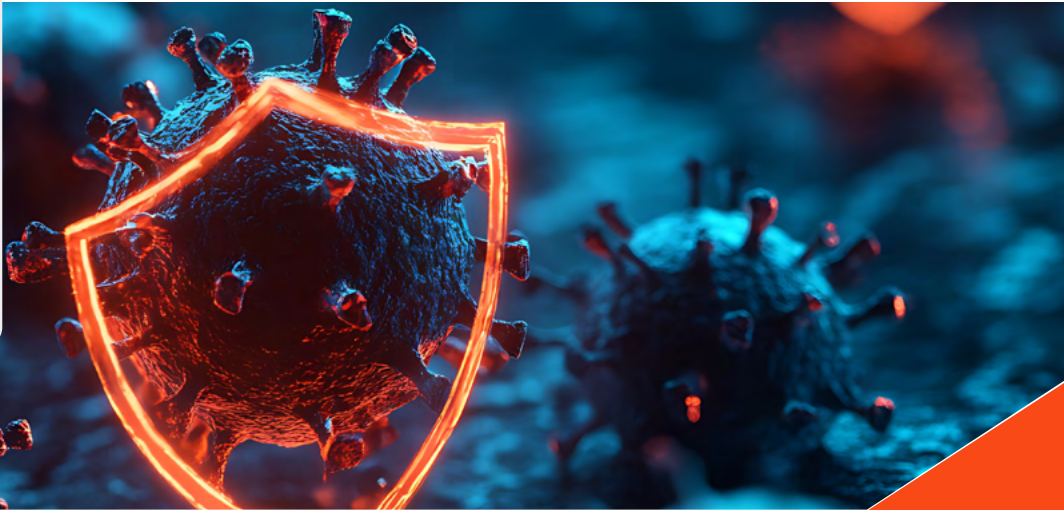


Figure 9. Share of total malware listings by type (top 5 of 200+ categories observed).



Hacktivism and State-Linked Activity

Hacktivism in 2025 was concentrated rather than evenly distributed. Activity clustered around Russia, Israel, India, and the United States, driven by the Russia-Ukraine war, Middle East conflicts, and Israel-Palestine dynamics, with targeting extending to countries perceived as supporting involved parties.

Hacktivism victims by geography

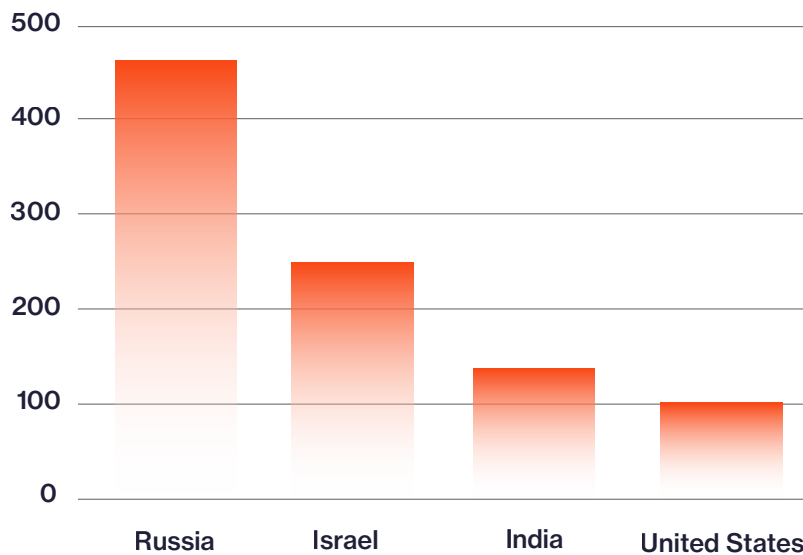


Figure 10. Hacktivism victims by number of observed incidents.

Technology was the most affected sector, followed by Government/Politics, Education, and Business Services. While 293 incidents had no identified sector, hacktivists consistently favored organizations that were visible, symbolically significant, or politically connected, suggesting targeting is deliberate rather than opportunistic.

Hacktivism victims
by sector

Hacktivism should not be treated as random noise. Exposure may depend less on size or revenue and more on where an organization operates, what it represents, how disruptive it would be if attacked, and how easily it can amplify a political message. That makes domino-style disruption more attractive: attackers can create a large impact by targeting organizations whose outages or vendor relationships affect many others.

State-linked activity also remained significant. APTs were observed targeting telecommunications, critical infrastructure, government, and technology environments, not only for immediate disruption, but for persistent access, intelligence gathering, and strategic pre-positioning. Unlike financially motivated actors, state-linked groups are often playing a longer game, embedding within systems months or years before their presence is detected or their objectives become clear.

Taken together, hacktivism and state-linked activity reflect two sides of the same geopolitical dynamic: one loud and symbolic, the other quiet and strategic. Both are shaped by the same global tensions and both are likely to intensify as those tensions remain unresolved.

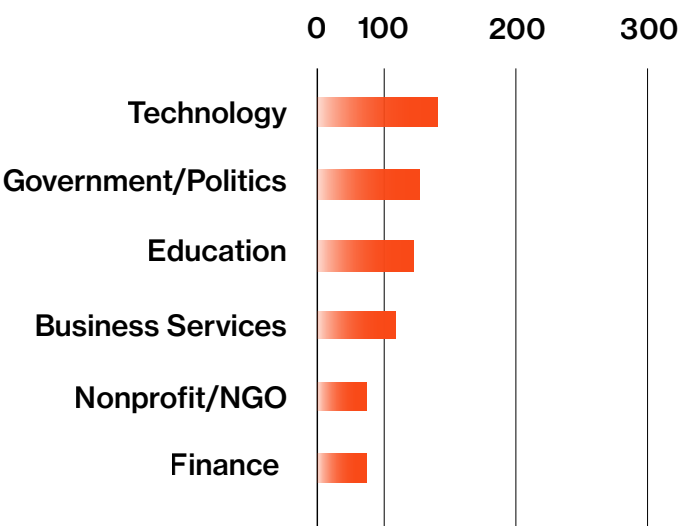


Figure 11. Hacktivism victims by observed incidents per sector.

Key takeaways

Hacktivist activity in 2025 clustered around Russia, Israel, India, and the United States, tracking closely with active geopolitical conflicts.

Technology, Government/Politics, and Education were the most targeted sectors.

State-linked APTs prioritized telecommunications, critical infrastructure, and government environments for long-term access.

Exposure to hacktivism depends more on where an organization operates and what it represents than on its size or revenue.

Endpoint logs

Endpoint log activity suggests the ecosystem is changing shape rather than fading. Visible log volume rose from 6.78 million in 2023 to 7.85 million in 2024, then fell to 3.95 million in 2025. That drop may suggest slowing activity, but stealer market composition also changed significantly.

While many countries experienced a drop in endpoint log targeting, the United States and China saw notable increases, rising 46% and 181%, respectively. Endpoint logs often represent the starting point for broader attacks, and the increase in the United States and China suggests threat actors are concentrating activity in strategically important markets, whether for financial, operational, or geopolitical reasons.

Relative change in endpoint logs in endpoint logs

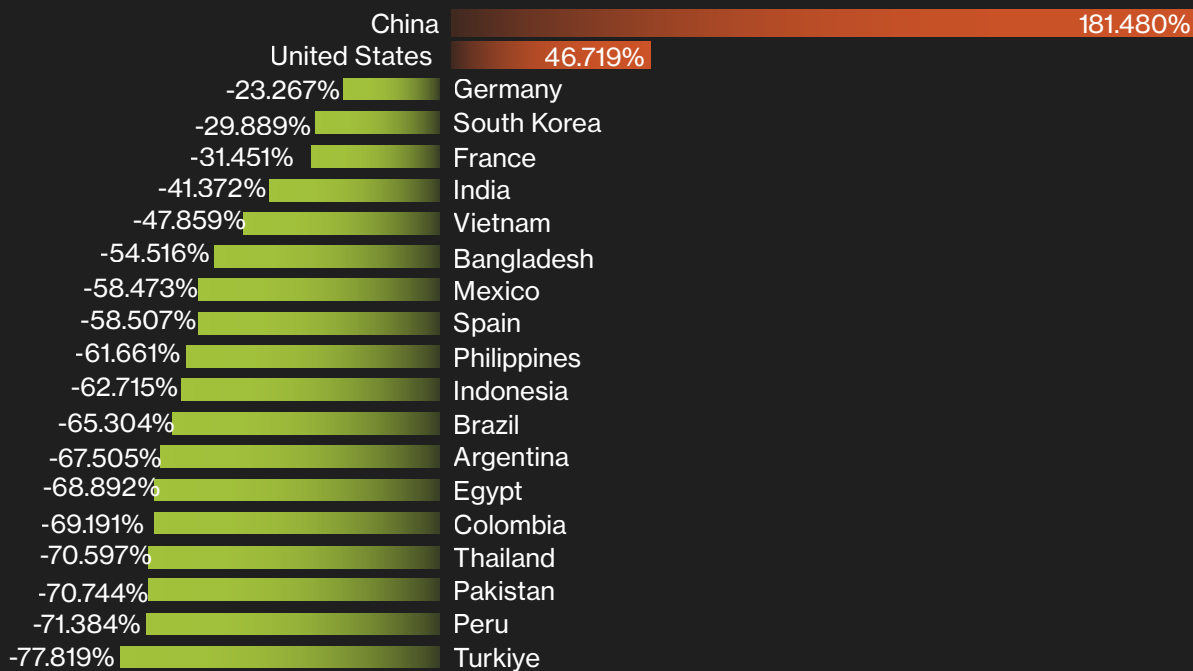


Figure 12. Relative change in endpoint log volume by location.

Lumma Stealer remained the most prevalent stealer family, though volume fell from 3.8 million logs in 2024 to 1.93 million in 2025, due in part to the disruption of its infrastructure as discussed earlier. Other established families also declined sharply. At the same time, newer or previously less prominent families grew quickly, suggesting a pattern consistent with disruption, operator churn, and rapid market replacement.

Malware family activity comparison (2024 vs 2025)

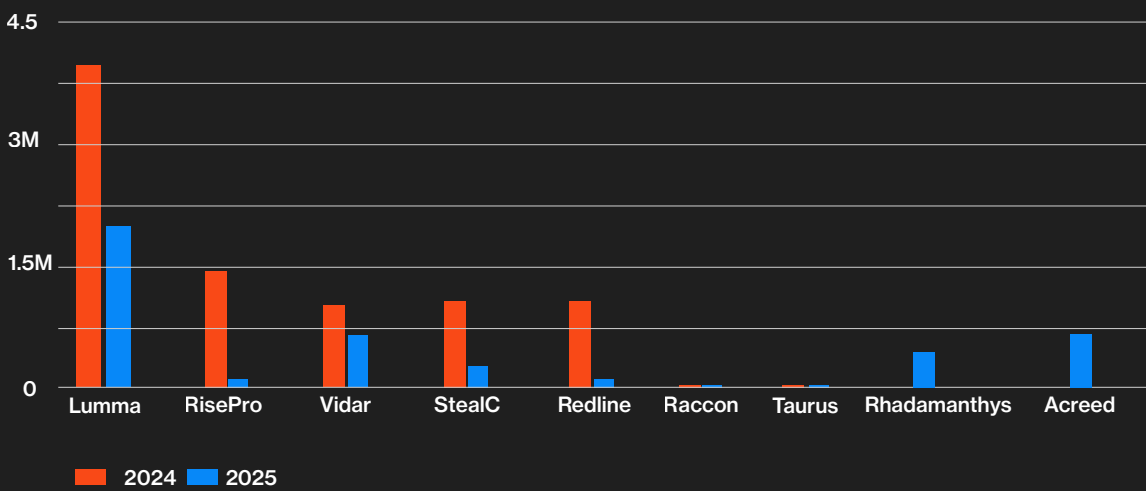


Figure 12. Top stealers seen for compromising endpoints.

Key takeaways

Visible endpoint log volume fell from 7.85 million in 2024 to 3.95 million in 2025, but the market structure shifted rather than contracted.

Stealer family turnover was high, with operator churn and rapid market replacement indicating an adaptive, competitive ecosystem.

A single compromised endpoint can expose credentials, session tokens, and corporate application access, making endpoint risk a gateway to broader intrusion.

What remains constant, regardless of which families dominate, is the consequence of a successful infection. A single infected device can expose browser credentials, session tokens, saved payment information, and corporate application access, thereby enabling account takeover, fraud, ransomware, business email compromise, or cloud intrusion. The initial infection is an entry point, not the end goal.

Compromised Credentials

Compromised credentials remained a major indicator of persistent exposure. Bitsight collected 397 million unique compromised credential sets in 2022, 2.6 billion in 2023, 3.6 billion in 2024, and 2.8 billion in 2025, a compound annual growth rate of 92% over the period. Even with a 22% decline from 2024, 2025 totals were more than seven times higher than in 2022.

Compromised credentials

These figures represent unique credential sets where username and password combinations are observed for the first time; reuse and resale of previously exposed credentials are not counted again. Fluctuations may reflect both compromise activity and the rate at which newly observed credentials enter monitored datasets. Expanded collection capabilities beginning in 2023 also contributed to higher observed volumes in subsequent years.

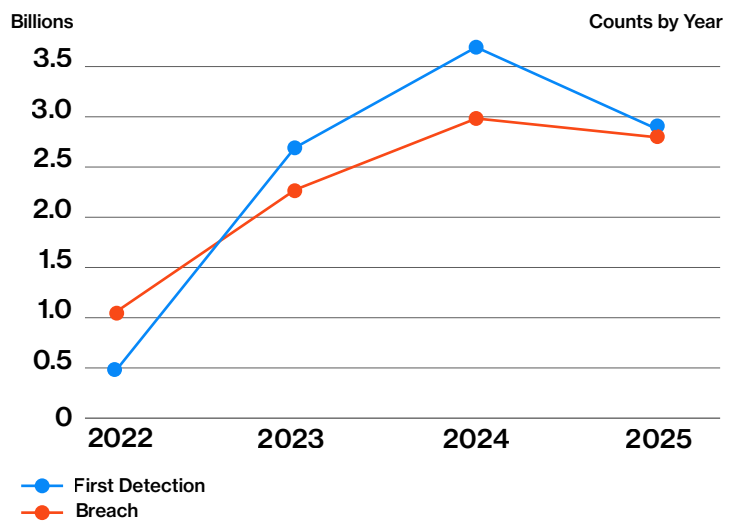


Figure 14. Credentials observed by first detection vs. breach event.



The 2025 decline should be interpreted carefully. A lower count of newly observed combinations does not necessarily mean credential theft declined at the same rate. It may reflect that fewer new credentials are entering monitored forums and markets as password rules become stronger.

Credential exposure is now operating at a structurally higher baseline. AI is beginning to amplify downstream risk by making phishing, account profiling, and compromised identity reuse easier to execute at scale, lowering the effort required to turn stolen credentials into successful intrusions. Organizations should focus on limiting impact through stronger authentication, abuse monitoring, and identity-layer resilience.

Key takeaways

2.8B

Bitsight collected 2.8 billion unique compromised credential sets in 2025, a 22% drop from 2024 but more than seven times the 2022 total.

+92%

Credential volumes grew at a 92% compound annual rate from 2022 to 2025, establishing a structurally elevated baseline.

Declining new-credential volume may reflect reuse of existing credentials rather than reduced theft activity.

AI-assisted phishing and identity profiling could amplify the impact of the existing credential stockpile.



Credit cards

In 2025, 10,605,063 compromised credit cards were listed for sale on underground markets, a 27% drop from 2024. Similar to other declines we observed, this likely reflects changing attacker behavior rather than a meaningful reduction in payment fraud risk.

As EMV tokenization, digital wallet security, and transaction-specific cryptograms make stolen card numbers harder to reuse, attackers may be shifting toward higher-value or easier-to-monetize data, including account credentials, full identity records, session cookies, and access to financial or retail accounts. That shift is consistent with the credential volumes and account takeover trends discussed earlier in this report.

Compromised credit cards

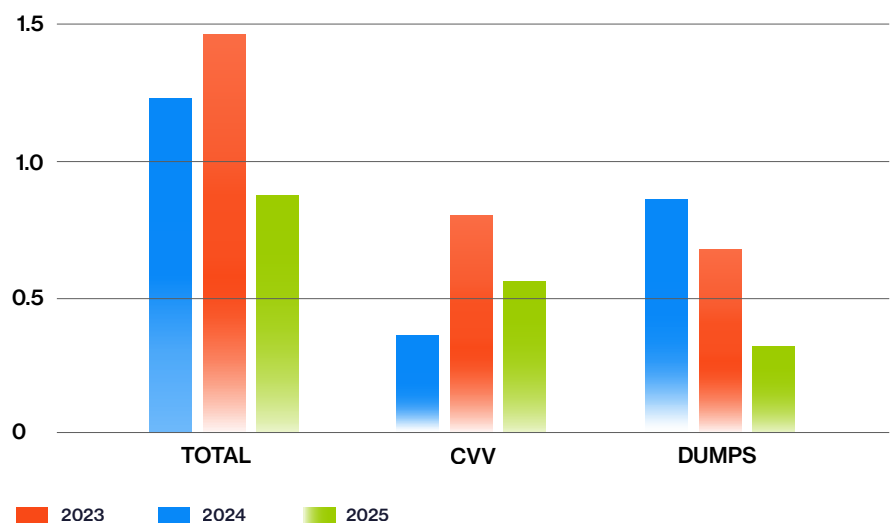


Figure 15. Number of compromised credit cards listed for sale on underground markets over the past three years.

Most compromised per country

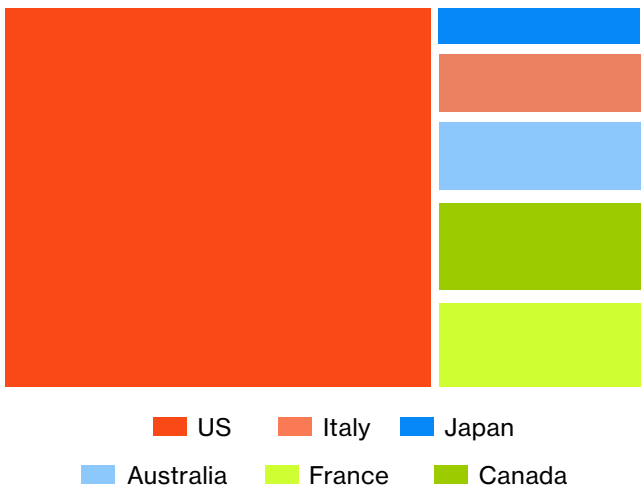


Figure 16. Compromised credit card share by country.

The United States continued to account for most compromised cards, with more than 9 million listed in 2025, accounting for roughly 88% of all compromised cards observed. Outside the United States, listings were more distributed, with France, Canada, Australia, Italy, Japan, and the United Kingdom accounting for smaller shares.

Compromised cards US vs. global

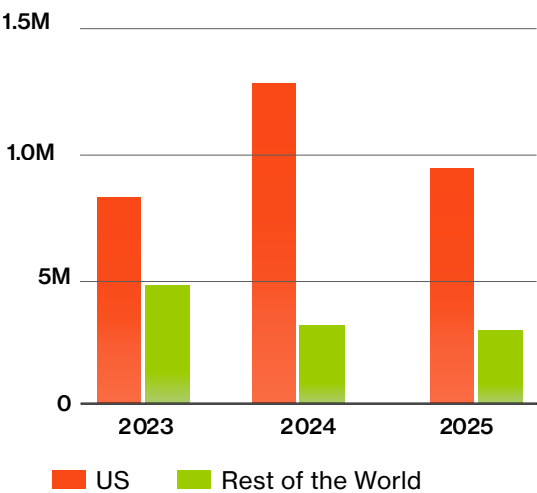


Figure 17. Number of compromised credit cards from the US versus global.

Dumps vs. CVV

The balance between dumps and CVV listings also continued to shift. Dumps, or magnetic stripe data typically stolen from physical point-of-sale systems, declined from 2023 to 2024 while average listing prices increased. CVV listings, tied to e-commerce compromise, rose sharply in 2024 and remained significant in 2025, driven by the continued growth of card-not-present fraud in online retail environments..

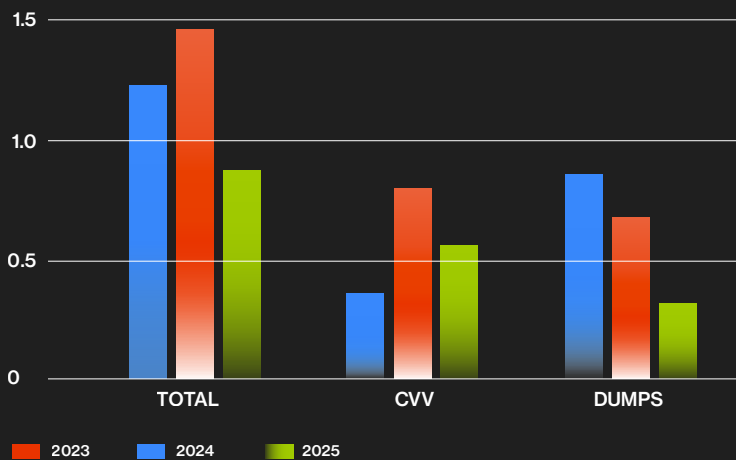


Figure 18. Number of cards identified as Dumps vs. CVVs over the past three years.

Payment card data remains a durable underground commodity, especially when it originates from the United States. Declining listing volumes do not signal a retreat from payment fraud; they signal a reorganization around data that enables broader, more persistent access. Stolen card numbers are increasingly a means to an end, feeding into account takeover, synthetic identity fraud, and financial account access rather than direct card-present transactions.

Key takeaways

10.6 M

compromised cards were listed in 2025, a 27% decline from 2024 that likely reflects attacker behavior shifts, not reduced fraud.

88%

The United States remained the dominant source, representing 88% of all observed listings.

The shift from dumps to CVVs signals continued attacker focus on e-commerce and card-not-present fraud channels.

Payment card data remains a durable underground commodity; declining listings may indicate migration to higher-value data types rather than reduced activity.

Vulnerabilities and exploits

In 2025, Bitsight observed nearly 34 million unique vulnerable IPs and more than 166,000 unique vulnerable entities, a 45% increase in vulnerable IPs and a 27% increase in vulnerable entities compared with 2024. The 10 Known Exploited Vulnerabilities (KEV) from 2025 affecting the greatest number of entities all carried Bitsight Dynamic Vulnerability Exploit (DVE) and CVSS scores above 9, reflecting both the severity and the breadth of active exploitation risk.

CVE	PUBLICATION DATE	HIGHEST DVE SCORE	VENDOR	PRODUCT	MOST AFFECTED COUNTRY	MOST AFFECTED SECTOR
<u>CVE-2025-0108</u>	2025-02-12	9.84	Palo Alto Networks	PAN-OS	US	Telecommunications
CVE-2025-4632	2025-05-13	9.76	Samsung	MagicINFO 9 Server	PY	Telecommunications
CVE-2025-6543	2025-06-25	9.99	Citrix	NetScaler ADC and Gateway	US	Telecommunications
CVE-2025-7775	2025-08-26	9.2	Citrix	NetScaler	US	Telecommunications
CVE-2025-24472	2025-02-11	9.96	Fortinet	FortiOS	US	Telecommunications
CVE-2025-24813	2025-03-10	10	Apache	Tomcat	US	Information Technology and Services
CVE-2025-48703	2025-09-19	9.94	CWP	ControlWeb Panel	US	Internet
CVE-2025-54236	2025-09-09	10	Adobe	Commerce and Magento	US	Information Technology and Services
CVE-2025-59718	2025-12-09	10	Fortinet	Multiple Products	US	Telecommunications

Key takeaways

+45%

Bitsight observed nearly 34 million unique vulnerable IPs in 2025, a 45% increase from 2024.

+27%

Vulnerable entities grew 27% to more than 166,000, with the US as the most exposed country across nearly all top KEVs.

10 KEVs

All 10 of the highest-impact KEVs carried DVE and CVSS scores above 9, with Telecommunications and IT/Services as the most affected sectors.

Public PoC availability and AI-assisted exploit adaptation are compressing the window between vulnerability disclosure and active exploitation.

The United States was the most exposed country for nearly all of these vulnerabilities. The most affected sectors—Telecommunications, IT and Services, and Internet—are industries whose compromise creates cascading risk across dependent organizations and supply chains. Bitsight TI also observed public proof-of-concept (PoC) code for these vulnerabilities, with some linked to threat actor or ransomware group interest.

Timing is more critical than ever. Public exploitability, attacker awareness, and broad exposure reduce the defender window between disclosure and exploitation. AI-assisted research and exploit adaptation may amplify this risk by making it easier to convert public vulnerability information into usable attack paths. DVE scores help highlight this urgency by combining exploitability, exposure, and threat context into a single prioritization signal.

The most important question for defenders is no longer just whether a vulnerability is severe but whether it is relevant. Mythos and other frontier AI models are enabling attackers to identify and act on that relevance faster than ever. A CVE affecting a key supplier, managed service provider, telecom provider, or software platform may create indirect exposure even when the vulnerable system is not inside the organization's own perimeter. Defenders need to know which threat actors are targeting applicable CVEs, which industries they favor, and where vendor relationships may create inherited risk.

In an environment where the gap between discovery and exploit window is shrinking, relevance-based prioritization is now the baseline.

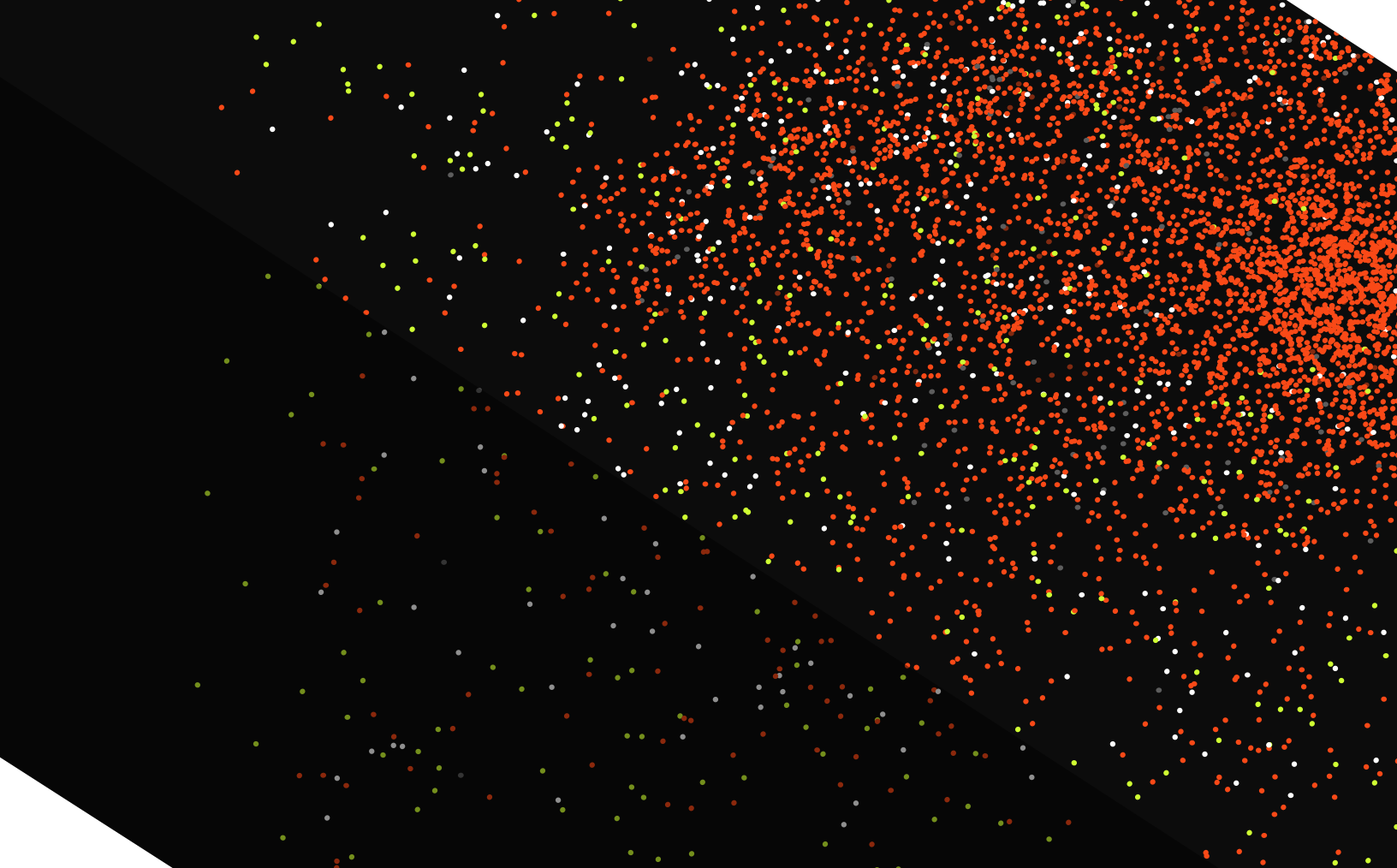
Conclusion

The threat landscape in 2025 did not get safer; it changed shape. Ransomware and hacktivism increased, AI became more visible in attacker workflows, and geopolitical tensions pushed threat actors toward higher-impact targets.

Lower counts in some datasets, including breaches, endpoint logs, credentials, and card listings, should not be read as reduced risk. They may reflect disruption efforts, reporting gaps, visibility changes, data reuse, or shifts in attacker behavior. Not every breach is reported, and state-linked actors rarely advertise successful attacks.

For defenders, the priority is knowing what matters most. The key question is not just which CVEs are severe, but which threat actors target CVEs that apply to your organization, your industry, and your vendors. Tools like Mythos and other frontier AI models can help connect vulnerability exposure, attacker behavior, and third-party risk.

The takeaway is clear: sharpen prioritization, harden identity, monitor vendors, and maintain strong controls, not relax them.



Appendix

Threat Actors

A relatively small number of ransomware groups accounted for a disproportionate share of activity in 2025. While 115 groups were active in the dataset, the most prolific actors were responsible for a large share of all posted attacks. The profiles below focus on the groups that appeared most frequently in the 2025 data and illustrate the broader dynamics shaping the ransomware ecosystem. More in-depth attacker profiles can be found in the appendix.

A relatively small number of ransomware groups accounted for a disproportionate share of activity in 2025. While 115 groups were active in the dataset, the most prolific actors were responsible for a large share of all posted attacks. The profiles below focus on the groups that appeared most frequently in the 2025 data and illustrate the broader dynamics shaping the ransomware ecosystem.

QILIN

[OPERATIONAL SINCE]

At least 2022

[MODEL]

Ransomware-as-a-service

[WHY IT STANDS OUT]

The most active ransomware group in 2025 at 911 confirmed attacks, scaling quickly through an affiliate model

[TOP TARGETS]

Manufacturing, professional services, healthcare, construction, and finance; most targeted countries include the United States, France, Canada, South Korea, and Spain

[COMMON ACCESS OR TRADECRAFT]

Affiliate-led intrusions, Windows and Linux targeting, including VMware ESXi; AES and RSA encryption

[PRIMARY PRESSURE TACTIC]

Double extortion through encryption and threats to publish stolen data

[KEY RISK]

Qilin shows how newer ransomware groups can scale quickly, reuse proven tradecraft, and create significant disruption in a short period of time

CIOP

[OPERATIONAL SINCE]

At least 2019

[MODEL]

Extortion-focused ransomware and data theft

Why it stands out: Known for turning high-impact software vulnerabilities into broad, multi-victim extortion campaigns, 478 confirmed attacks in 2025. Gained notoriety for their large-scale Movelt breach in 2022 in which 91 million individuals were impacted. CIOP was observed stating that this targeting was due to perceived support of Ukraine.

[TOP TARGETS] Healthcare, consumer goods, business services, manufacturing, food production, government, retail, and technology; especially active in the United States and Europe

[COMMON ACCESS OR TRADECRAFT]

Aggressive exploitation of enterprise software vulnerabilities, especially managed file transfer platforms; tools and techniques include Mimikatz, Cobalt Strike, and custom exfiltration tooling

[PRIMARY PRESSURE TACTIC] Data theft and extortion, sometimes without deploying encryption at all

[KEY RISK]

Qilin shows hoCIOP highlights the growing importance of third-party software risk, where a single platform vulnerability can create exposure across many organizations at once

AKIRA

[OPERATIONAL SINCE]

March 2023

[MODEL]

Ransomware-as-a-service

[WHY IT STANDS OUT]

A fast-growing operation that has combined affiliate scale with consistent execution against exposed systems. They accounted for 670 confirmed attacks in 2025

[TOP TARGETS]

Small and medium-sized businesses, with expansion into larger organizations and critical infrastructure; key sectors include manufacturing, healthcare, technology, finance, and education; activity concentrated in the United States, the United Kingdom, Canada, Germany, and Australia

[COMMON ACCESS OR
TRADECRAFT]

Exploitation of internet-facing systems, especially VPN appliances and backup solutions, plus compromised credentials; tools such as AnyDesk and LogMeIn; evolving payloads including Rust-based variants

[PRIMARY PRESSURE TACTIC] Double extortion through data theft and encryption

[KEY RISK]

Akira reinforces how effective ransomware groups can remain without radically new tactics, especially when remote access paths are weak against exposed systems and access controls continue to produce significant results.

TIONS AT ONCE

[OPERATIONAL SINCE]

AT LEAST JUNE 2022

[MODEL]

RANSOMWARE

[WHY IT STANDS OUT]

A steady operator focused on organizations where operational disruption can quickly create leverage, 365 confirmed attacks in 2025

[TOP TARGETS]

Manufacturing, engineering, retail, business services, transportation, and other operationally sensitive sectors; most affected countries include the United States, Canada, the United Kingdom, Germany, and Australia

[COMMON ACCESS OR TRADECRAFT]

Proven post-compromise techniques, including tools like AdFind for Active Directory reconnaissance; some reported infrastructure overlap with other ransomware ecosystems

[PRIMARY PRESSURE TACTIC]

Encryption and operational disruption

[KEY RISK]

Play reflects a familiar but durable ransomware model: target organizations where downtime matters, then use established tools to increase pressure quickly

INC Ransom

[OPERATIONAL SINCE]

At least July 2023

[MODEL]

Ransomware

[WHY IT STANDS OUT]

Combines common access methods with high-pressure extortion tactics designed to heighten urgency, 345 attacks in 2025

[TOP TARGETS]

Healthcare, education, and industrial organizations, with significant concentration in the United States and Europe

[COMMON ACCESS OR TRADECRAFT]

Exploitation of internet-facing systems, spearphishing, and purchased credentials; use of WMIC, PsExec, and Netscan for lateral movement and low-noise administration

[PRIMARY PRESSURE TACTIC]

Fast encryption, partial encryption, and reputation pressure, including printing ransom notes on connected printers

[KEY RISK]

INC Ransom shows how known vulnerability exploitation, credential-based access, and legitimate administrative tooling continue to produce results without especially novel tradecraft

APTs

Several APT groups accounted for a disproportionate share of attacks in 2025. The following profiles highlight some of the most active and operationally significant groups observed during the year. APTs are understood to be generally state or government sponsored organizations, with AI also becoming a relevant piece of this landscape.

China

Salt Typhoon

Category	Details
Aliases	FamousSparrow, GhostEmperor, OPERATOR PANDA, RedMike, SLIME57, UNC2286, UNC4841
Reported Affiliation	Linked in reporting to Sichuan Juxinhe Network Technology Co., LTD
Primary Objective	Espionage and strategic intelligence collection
Targeted Industries	Telecommunications, ISPs, government, technology
Targeted Geographies	United States, Netherlands, Europe, Africa, Asia
Notable Targets	AT&T, Verizon, T-Mobile, Lumen
Observed CVEs	CVE-2023-7102, CVE-2023-46805, CVE-2021-36260, CVE-2021-28199
Associated Tooling	SparrowDoor, JumbledPath
Key Risk	Long-duration access to communications infrastructure

Volt Typhoon

Category	Details
Aliases	BRONZE SILHOUETTE, DEV-0391, Insidious Taurus, Redfly, Storm-0391, UAT-5918, UAT-7237, UNC3236, UNC5291, VANGUARD PANDA, VOLTZITE
Reported Affiliation	Associated in reporting with China-linked espionage activity
Primary Objective	Long-term espionage and strategic access to critical infrastructure
Targeted Industries	Government/Politics, Manufacturing, Energy/Resources, Utilities, Telecommunications, Technology, Transportation, Healthcare/Wellness
Targeted Geographies	United States, Guam, Taiwan, Singapore
Notable Targets	Critical infrastructure organizations in the United States and its territories
Observed CVEs	CVE-2019-1652, CVE-2019-1653, CVE-2023-46805, CVE-2024-21887, CVE-2024-39717, CVE-2025-5777, CVE-2025-6543
Associated Tooling	VersaMem, ScanLine, KV
Key Risk	Long-duration access to critical infrastructure environments that could support surveillance, disruption, or pre-positioning during periods of heightened geopolitical tension.

Flax Typhoon

Category	Details
Aliases	Ethereal Panda, RedJuliett
Reported Affiliation	Associated in reporting with China-linked espionage activity; linked by Bitsight TI to Integrity Technology Group, Inc.
Primary Objective	Cyber espionage and long-term access to targeted networks
Targeted Industries	Education, Telecommunications, Technology, Media/ Entertainment, Utilities, Engineering
Targeted Geographies	Taiwan, China, United States, Philippines, Hong Kong, India
Notable Targets	Government agencies, aerospace and defense contractors, technology firms, entities related to U.S.-Philippines military exercises
Observed CVEs	Not specified
Associated Tooling	BlackKingdom, JuicyPotato, Nosedive, Mimikatz, Godzilla web shell, ArcGIS web shell modification
Key Risk	Long-term access through public-facing systems and trusted components, enabling persistence, lateral movement, and credential harvesting in strategically sensitive environments.

Russia

Sandworm

Category	Details
Aliases	Unit 74455, Voodoo Bear, TeleBots
Reported Affiliation	Linked in reporting to Russia's Main Intelligence Directorate (GRU)
Primary Objective	Disruption and strategic impact against critical infrastructure
Targeted Industries	Energy/Utilities, Government, Telecommunications, IT, Finance, Transportation
Targeted Geographies	Ukraine, Eastern Europe, broader Europe (including Poland)
Notable Targets	Ukraine power grid, Viasat satellite communications, European infrastructure providers
Observed CVEs	Not specified
Associated Tooling	DynoWiper, AcidRain, VPNFilter
Key Risk	Use of destructive wiper malware and infrastructure-targeted attacks designed to disrupt operations, degrade critical services, and create strategic impact during geopolitical conflict.

APT28

Category	Details
Aliases	Fancy Bear, Forest Blizzard, Sofacy, STRONTIUM
Reported Affiliation	Linked in reporting to Russia's military intelligence services
Primary Objective	Espionage, strategic intelligence collection, and influence operations
Targeted Industries	Government, Military/Defense, Political organizations
Targeted Geographies	United States, Europe, Ukraine
Notable Targets	Democratic National Committee, German Parliament, European government and defense organizations
Observed CVEs	Microsoft Office vulnerabilities, Windows Print Spooler vulnerabilities
Associated Tooling	GooseEgg, Covenant, BEARDSHELL, SLIMAGENT, EdgeOS router infrastructure
Key Risk	Persistent espionage and influence operations targeting government, defense, and political organizations, with continued reliance on vulnerability exploitation, credential-based access, and spear-phishing.

GRU-linked cyber operations

Category	Details
Aliases	GRU operations, Russian military intelligence-linked activity
Reported Affiliation	Linked in reporting to Russia's Main Intelligence Directorate (GRU)
Primary Objective	Disruption, espionage, strategic signaling, and pre-positioning
Targeted Industries	Government, Information Technology, Energy, Finance, Transportation, Communications, Military/Defense
Targeted Geographies	Ukraine, Europe, Poland, NATO-affiliated environments
Notable Targets	Ukrainian government entities, Ukrainian financial institutions, Viasat, Polish transportation sector, NATO-affiliated organizations
Observed CVEs	Not specified
Associated Tooling	Wiper malware, distributed denial-of-service activity, reconnaissance infrastructure
Key Risk	GRU-linked operations combine destructive activity, espionage, and strategic pressure, creating elevated risk for organizations tied to critical infrastructure, government, defense, transportation, energy, and communications.

Iran

MuddyWater

Category	Details
Aliases	Mango Sandstorm, Static Kitten, Earth Vetala
Reported Affiliation	Linked in reporting to Iran's Ministry of Intelligence and Security (MOIS)
Primary Objective	Espionage and regional intelligence collection
Targeted Industries	Government, Telecommunications, Energy, Private-sector organizations
Targeted Geographies	Middle East, North Africa, broader international targets
Notable Targets	Organizations across the Middle East and North Africa; Operation Olalampo targets
Observed CVEs	CVE-2024-4577, CVE-2025-32433, CVE-2026-21514, CVE-2026-1731, CVE-2024-23113, CVE-2026-1281, CVE-2024-55591, CVE-2025-68613, CVE-2025-9316, CVE-2025-54068
Associated Tooling	DinDoor, Tsundere botnet variant, FakeSet, CastleLoader, RustyWater, GhostFetch, CHAR, HTTP_VIP
Key Risk	Low-noise espionage activity using public exploits, phishing, remote management tools, and legitimate services to gain and maintain access while blending into normal administrative activity.

Imperial Kitten

Category	Details
Aliases	Tortoiseshell
Reported Affiliation	Linked in reporting to Iran's Islamic Revolutionary Guard Corps (IRGC)
Primary Objective	Espionage and long-term intelligence collection through social engineering
Targeted Industries	Telecommunications, Aerospace/Defense, Government/Politics, Transportation, Manufacturing, Technology
Targeted Geographies	Germany, United Arab Emirates, United States, France, Western Europe (Denmark, Portugal, Sweden)
Notable Targets	Critical infrastructure and defense-related organizations in Europe and the Middle East
Observed CVEs	CVE-2024-1709
Associated Tooling	Minibike, MiniBrowse, MiniJunk, Bondupdater, IMAPLoader, Liderc
Key Risk	Long-term, trust-based access achieved through social engineering and persistent engagement, enabling credential theft, malware deployment, and espionage activity that is difficult to detect.

Charming Kitten

Category	Details
Aliases	APT35, Phosphorus, Mint Sandstorm
Reported Affiliation	Linked in reporting to Iran's Islamic Revolutionary Guard Corps (IRGC)
Primary Objective	Espionage and strategic intelligence collection
Targeted Industries	Government/Politics, Telecommunications, Transportation, Technology
Targeted Geographies	United States, Middle East, Europe
Notable Targets	Government and military entities, Israeli cybersecurity experts
Observed CVEs	CVE-2024-3400, CVE-2021-27065, CVE-2021-26858, CVE-2021-26857, CVE-2022-47966, CVE-2021-45046, CVE-2021-26855, CVE-2021-21972, CVE-2018-13379
Associated Tooling	Mamba, LittleLooter, BitLocker, DownPaper, TelegramGrabber, TurnedUp, MacDownloader, SysKit, PowerLess, Pineflower, MediaPI, Chairsmack, CharmPower, Pupy, StoneDrill, Drokbnk
Key Risk	Persistent, phishing-driven intrusion campaigns combining credential theft, malware deployment, and infrastructure abuse, enabling long-term access and strategic intelligence collection.

North Korea

Lazarus Group

Category	Details
Aliases	Labyrinth Chollima, HIDDEN COBRA, ZINC, Jade Sleet, Citrine Sleet
Reported Affiliation	Linked in reporting to North Korea's Reconnaissance General Bureau (RGB)
Primary Objective	Espionage, disruption, financial theft, and cryptocurrency-focused operations
Targeted Industries	Healthcare/Wellness, Finance, Energy/Resources, Utilities, Media/Entertainment, Technology, Manufacturing, Transportation, Business Services, Consumer Goods, Government/Politics, Education
Targeted Geographies	South Korea, India
Notable Targets	Sony Pictures Entertainment, Harmony's Horizon Bridge, 3CX, Archblock, Robinhood, eToro, Bybit, Gemini Crypto, Balancer Protocol
Observed CVEs	Not specified
Associated Tooling	TAXHAUL, Coldcat, VEILED SIGNAL, AppleSeed
Key Risk	Highly adaptive operations spanning espionage, cryptocurrency theft, supply chain compromise, and social engineering, creating risk across both traditional enterprise environments and fintech/Web3 ecosystems.

Kimsuky

Category	Details
Aliases	APT43, Archipelago, Black Banshee, THALLIUM
Reported Affiliation	Linked in reporting to North Korea's Reconnaissance General Bureau (RGB)
Primary Objective	Espionage, strategic intelligence collection, and financial activity supporting broader state objectives
Targeted Industries	Manufacturing, Energy/Resources, Business Services, Government/Politics, Education, Technology, Finance, Credit Unions
Targeted Geographies	Europe, Japan, South Korea, United States, United Kingdom
Notable Targets	Genians; organizations tied to foreign policy, Korean Peninsula security issues, nuclear policy, and sanctions
Observed CVEs	CVE-2015-2545, CVE-2017-0199, CVE-2018-8174, CVE-2019-0604, CVE-2022-30190, CVE-2024-1709, CVE-2025-0282, CVE-2025-0283, CVE-2025-0411, CVE-2025-22457
Associated Tooling	AppleSeed, PebbleDash, X RAT, Amadey, RftRAT, AutoIt-based malware
Key Risk	Persistent phishing-driven operations that combine espionage, malware delivery, vulnerability exploitation, and credential theft against strategically relevant targets.

Category	Details
Aliases	Sapphire Sleet, APT38, Alluring Pisces, Stardust Chollima, TA444
Reported Affiliation	Linked in reporting to North Korea; widely tracked as a sub-cluster of Lazarus Group
Primary Objective	Financial theft, cryptocurrency theft, and access to fintech and blockchain-related environments
Targeted Industries	Finance, Cryptocurrency/Web3, Technology, Healthcare/Wellness, Education, Government/Politics
Targeted Geographies	Africa, Argentina, Asia, Canada, Chile, Costa Rica, Mexico, United States
Notable Targets	Financial institutions, cryptocurrency exchanges, executives, Web3 developers, blockchain professionals
Observed CVEs	CVE-2021-40449, CVE-2025-48384, CVE-2022-0609
Associated Tooling	Modular malware written in Rust, C++, Python, Go, Swift, and Nim; AppleScript-based macOS execution; ClickFix-style social engineering
Key Risk	Highly tailored social engineering and cross-platform malware used to steal credentials, gain persistent access, and enable large-scale financial and cryptocurrency theft.